Security Playground

Project Plan

Nikola Panayotov

Table of Contents

1 Problem and Context....2
2 Proposed Solution (Project Description)....2
3 Project Goals....2
4 Scope and Constraints....2
5 Project Approach....3
6 Project Planning....3
7 Expected Deliverables....4
References....4

1 Problem and Context

Web applications and servers are attacked every day, and many successful attacks use common weaknesses such as weak authentication, missing access control, unsafe input handling and insecure network configuration (OWASP Foundation, 2021). Reading about these weaknesses does not show how they behave in practice, and testing them on live systems would be unsafe. A controlled environment is needed in which an application can be attacked on purpose and then secured.

The challenge question for this project is: how can a basic networked web application be built within the EDU Cloud, attacked, and improved using fundamental Linux or Windows tools? The project has not started yet. The exact application, the weaknesses to be tested and the tools allowed in the EDU Cloud still have to be defined. Defining them is the first part of the work.

The parties involved are the client, who receives the results, and the developer, who carries out the project. The intended end users of the application still have to be defined and will be confirmed with the client.

2 Proposed Solution (Project Description)

Security Playground is a project in which a small networked web application is built, attacked in a safe environment, improved, and tested again. The first idea is a simple application, SecureNotes, where users can create an account, log in and manage personal notes. This idea is not final and will be confirmed or changed in the Analysis.

The plan is to make two versions of the application. The unsecured version will be intentionally weak and will run only in an isolated environment, so that its weaknesses can be seen and tested. The secured version will be the improved version, with a fix for every finding. Both versions will be tested in the same way so that the results can be compared. The technologies and tools for building and testing the application have not been chosen yet. The options will be compared and chosen in the Advise activity.

3 Project Goals

The overall goal is to show, through practice, how a web application and its server become vulnerable and how they are secured. To reach this goal, the project has the following goals.

No.	Goal	What it means
G1	Develop a working web application.	A small application with user accounts and personal notes that works in a safe, isolated environment.
G2	Identify and demonstrate security vulnerabilities.	Find common web and network weaknesses in the unsecured version and show them with evidence.
G3	Secure the application.	Fix every demonstrated vulnerability in the secured version.
G4	Verify that the security improvements work.	Test the secured version with the same test cases and compare it with the unsecured version.
G5	Run the application safely.	Run the unsecured version only in an isolated environment and the secured version on a protected server.
G6	Document the work so that it can be repeated.	Document the findings, fixes and results clearly, so that someone else can reproduce them.

4 Scope and Constraints

The scope is deliberately small so that there is enough time to test and improve, not only to build. The initial scope is one user role, simple user accounts and personal notes, and one deployment per environment.

Testing will focus on common web and network weaknesses (OWASP Foundation, 2021). The exact list of functions and weaknesses will be defined in the Analysis.

Features that need a lot of time but add little to the project goals are outside the scope, for example note sharing, file uploads, email functions, multiple user roles, high availability, custom exploits, malware and denial-of-service tests. Optional extras will only be considered if the core work is finished.

The following constraints apply. The unsecured version must never be exposed to the public internet and will only run in the EDU Cloud, a local virtual machine or an isolated network. Only systems that belong to the client or are provided for this project will be scanned or attacked. The tools that can be used depend on the rules of the EDU Cloud, which still have to be confirmed. The main risks at the start of the project are listed below.

Risk	Effect	Response
EDU Cloud restrictions on tools or access	Planned tests cannot be carried out.	Ask for the rules early and confirm them with the client. Keep a local virtual machine as a fallback.
Scope growth	Extra features leave less time for testing.	Keep the scope small and finish the core work first.
Too little time for retesting	The secured version cannot be compared fairly with the unsecured version.	Write the test cases before testing, record evidence while working and keep to the hours planned per activity.
Unclear requirements or late feedback	Work may have to be redone.	Confirm scope and goals with the client after the Analysis and after the Design.

5 Project Approach

The project will follow five activities in order: Analyse, Advise, Design, Realise and Validate. Each activity builds on the result of the previous one, so every decision can be traced back to the problem and every test back to a requirement.

First, the problem will be analysed, the scope and requirements defined and the EDU Cloud rules confirmed with the client. Then the technology options will be compared and a solution proposed. After that, the application, the environment and the test cases will be designed. In the Realise activity the unsecured version will be built first, in small steps, followed by the secured version. In the Validate activity both versions will be tested with the same test cases and the results compared, following a structured approach of planning, execution and reporting (Scarfone et al., 2008).

Notes and evidence will be kept while the work is done instead of being written afterwards. Client feedback will be requested after the Analysis and after the Design.

6 Project Planning

The table below shows the planned time for each activity.

Activity	Hours
Analyse	20 h
Advise	15 h
Design	25 h
Realise	55 h
Validate	25 h

7 Expected Deliverables

At the end of the project the following will be delivered.

Deliverable	What is delivered
1. SecureNotes Unsecured	A working, intentionally vulnerable web application with registration, login and CRUD functionality for notes.
2. SecureNotes Secured	A secured version of the same application with fixes for the demonstrated vulnerabilities.
3. Source Code	A GitHub repository containing both versions, including frontend, backend and database code.
4. Deployment	Docker configuration for running the application and a working secured deployment on the Ubuntu VPS behind Nginx.
5. Security Test Results	Evidence of vulnerabilities in the unsecured version and retesting after fixes in the secured version, including screenshots, test cases and results.
6. Technical Documentation	Architecture diagrams, DB_Diagrams, configuration instructions and an explanation of the security improvements.
7. Final Report	A comparison of the unsecured and secured versions, with conclusions and recommendations.

What does the client actually receive?

Item	Content
GitHub Repository	Source code, configurations and instructions.
Working Web Application	The unsecured version running in an isolated environment and the secured version accessible through the VPS deployment.
Security Assessment	Documented vulnerabilities, proof-of-concept tests, applied fixes and before-and-after test results.

References

OWASP Foundation. (2021). *OWASP Top 10:2021*. https://owasp.org/Top10/

Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2008). *Technical guide to information security testing and assessment* (NIST Special Publication 800-115). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/115/final